COMPTIA PENTEST+ · PT0-003 · STUDY GUIDE

Domain 4 — Compare-&-Contrast Pairs + Mnemonics

The confusable pairs CompTIA builds distractors from — each with a one-line discriminator — plus memory hooks for the lists you have to recall cold.

Beat the "almost right" answers

CompTIA rarely tests a concept in isolation — it tests it *against its look-alike*. If you can state the single axis that separates two confusable items, the trap answer stops working. Part 1 gives you that discriminator for every high-value pair. Part 2 gives you hooks for the list-heavy bits that need cold recall.

Part 1 — Compare-&-Contrast Pairs

Reverse shell vs Bind shell

Axis	Reverse shell	Bind shell
Who connects	Target dials OUT to attacker	Attacker dials IN to target
Listener is on	The attacker	The target
Firewall/NAT	Traverses outbound easily	Fails if inbound is filtered

Discriminator: Who dials whom? **Reverse = target dials out** (beats firewalls/NAT). **Bind = attacker dials in.**

Stored vs Reflected vs DOM-based XSS

Axis	Stored	Reflected	DOM
Payload lives	On the server (persisted)	In the request, echoed back	In the browser only
Who's hit	Every viewer	Whoever clicks the crafted link	Whoever runs the client-side JS
Server sees it?	Yes (stored)	Yes (in request)	No — never reaches server

Discriminator: Where does the payload live? **Server (stored) · the request (reflected) · the browser DOM only (DOM).**

SQL injection vs Command injection

> **Discriminator:** Which interpreter eats the input? **The database engine = SQLi**; **the OS shell = command injection.** Both are the same "code/data confusion" bug at different interpreters.

Kerberoasting vs AS-REP roasting

Axis	Kerberoasting	AS-REP roasting
Targets	Accounts WITH an SPN (service accounts)	Accounts with pre-auth DISABLED
Creds needed	Yes — any valid domain user	No credentials needed
You crack	The TGS service ticket	The AS-REP response
Tool	Rubeus / `GetUserSPNs`	Rubeus / `GetNPUsers`

> **Discriminator: Kerberoast needs creds + targets SPNs**; **AS-REP needs no creds + targets pre-auth-disabled accounts.**

Pass-the-Hash vs Pass-the-Ticket vs Pass-the-Token

> **Discriminator:** What bearer material do you replay? **NTLM hash (PtH) · Kerberos ticket (PtT) · session/OAuth token (pass-the-token).** All exploit "possession = identity."

Golden ticket vs Silver ticket

Axis	Golden	Silver
You forge	A TGT (ticket-granting ticket)	A TGS (service ticket)
Key used	`krbtgt` account hash	The target service account's hash
Access	Whole domain	One specific service

> **Discriminator: Golden = forged TGT with krbtgt = the whole domain**; **Silver = forged service ticket = one service.**

SSRF vs CSRF

Axis	SSRF	CSRF
Who's tricked	The server makes the request	The victim's browser makes the request
Abuses	Server's network position (internal/metadata)	Victim's authenticated session (cookies)
Fix	Egress allowlist, block link-local	Anti-CSRF token, SameSite cookies

Discriminator: Who is the confused deputy? **The SERVER (SSRF)** vs **the victim's BROWSER (CSRF).**

CVE vs CWE vs CVSS vs EPSS

Term	Answers…	Example
CVE	*Which* specific vulnerability	CVE-2021-44228 (Log4Shell)
CWE	*What type* of weakness	CWE-89 = SQL injection
CVSS	*How severe* (0–10)	9.8 = critical
EPSS	*How likely* to be exploited	0.94 = very likely

Discriminator: CVE = which · CWE = what type · CVSS = how severe · EPSS = how likely exploited.

The phishing family

Term	Channel / target
Phishing	Email, broad/untargeted
Spear-phishing	Email, a specific person/org (tailored via OSINT)
Whaling	Spear-phishing aimed at executives ("big fish")
Vishing	Voice / phone call
Smishing	SMS / text message

Discriminator: Channel or target? **Email = phish · targeted = spear · exec = whale · voice = vish · SMS = smish.**

WEP vs WPA vs WPA2 vs WPA3

Standard	Crypto	Weakness
WEP	RC4 + IV	IV reuse → fast key recovery (broken)
WPA	TKIP	Interim fix, still weak
WPA2	AES-CCMP	4-way handshake crackable OFFLINE
WPA3	SAE (Dragonfly)	Resists offline cracking

Discriminator (weak→strong): WEP (IV reuse) < WPA (TKIP) < WPA2 (AES, offline-crackable handshake) < WPA3 (SAE, no offline crack).

Evil twin vs Rogue AP · LFI vs RFI

Evil twin vs Rogue AP: a rogue AP is *any* unauthorized AP; an **evil twin** is a rogue AP that **impersonates a legitimate SSID** to lure clients. (Every evil twin is a rogue AP; not every rogue AP is an evil twin.)

LFI vs RFI: Local File Inclusion = a file already on the server (e.g., `/etc/passwd`); **Remote File Inclusion = a file hosted on the attacker's server.**

SAST vs DAST vs IAST vs SCA

Type	What it does
SAST	Static — reads source code at rest (white-box), no execution
DAST	Dynamic — attacks the running app from outside (black-box)
IAST	Interactive — instrumented, watches from *inside* the running app
SCA	Software Composition Analysis — audits third-party dependencies

Discriminator: SAST reads code at rest · DAST attacks it running · IAST watches from inside · SCA checks your dependencies.

Fast pairs (one-liners)

Active vs Passive recon: you touch the target (active, detectable) vs never touch it (passive, OSINT).

Authenticated vs Unauthenticated scan: credentialed inside-view (fewer false positives) vs outside attacker-view.

IDS vs IPS: detects & alerts (IDS, passive) vs detects & blocks inline (IPS, active).

False positive vs negative: FP = false alarm (cries wolf) · FN = missed real threat (misses the wolf).

Encoding vs Encryption vs Hashing: reversible no-key (encoding) · reversible with key (encryption) · one-way (hashing).

Steganography vs Encryption: hide that a message exists (stego) vs scramble its content (encryption).

Session hijacking vs fixation: steal an existing session ID (hijack) vs plant one you already know (fixation).

NFC vs RFID: RFID = longer-range, one-way tags; NFC = very short-range (~4 cm), two-way — a special case of RFID.

Agreements (Dom 1): NDA = secrecy · MSA = master relationship · SOW = this specific job · ToS = usage rules.

Part 2 — Mnemonics & Memory Hooks

OWASP Top 10 (2021)

- A01 Broken Access Control · A02 Cryptographic Failures · A03 Injection
- A04 Insecure Design · A05 Security Misconfiguration · A06 Vulnerable/Outdated Components
- A07 Identification & Auth Failures · A08 Software/Data Integrity Failures
- A09 Logging/Monitoring Failures · A10 SSRF

Hook: the exact number order rarely matters — *recognition* does. Lock the pentest-heavy ones first: **A01 Access Control, A03 Injection, A10 SSRF** (plus A02 Crypto). Sentence for the sequence: "*Broken Crypto Injects Insecure Systems; Vulnerable Identities Silently Log Requests.*"

Common ports (grouped — memorize by cluster, not flashcard soup)

Cluster	Ports
Web	80 HTTP · 443 HTTPS · 8080 HTTP-alt
Remote access	22 SSH · 23 Telnet · 3389 RDP · 5900 VNC · 5985/5986 WinRM
Windows / AD	88 Kerberos · 135 MSRPC · 137–139 NetBIOS · 389 LDAP · 445 SMB · 636 LDAPS · 3268 Global Catalog
Email	25 SMTP · 110 POP3 · 143 IMAP · 465/587 SMTPS · 993 IMAPS · 995 POP3S
Databases	1433 MSSQL · 1521 Oracle · 3306 MySQL · 5432 Postgres · 6379 Redis · 27017 Mongo
Name / mgmt	53 DNS · 67/68 DHCP · 69 TFTP · 161/162 SNMP

Hook: "**445 = SMB**" and "**3389 = RDP**" are the two you'll see most in pentest scenarios — burn those in first. SMB pair: **139** (NetBIOS) and **445** (modern SMB).

Hash identification by length (hex characters)

Length	Likely hash
32	MD5 *or* NTLM (distinguish by context — AD dumps = NTLM)
40	SHA-1
64	SHA-256
128	SHA-512

Hook: "**32 · 40 · 64 · 128**." bcrypt is the odd one out — it starts with `$2a$/$2b$`, not a fixed-length hex string.

STRIDE — threat categories (threat modeling)

- **S**poofing → breaks Authentication
- **T**ampering → breaks Integrity
- **R**epudiation → breaks Non-repudiation
- **I**nformation disclosure → breaks Confidentiality
- **D**enial of service → breaks Availability
- **E**levation of privilege → breaks Authorization

Hook: STRIDE maps one-to-one onto the security properties it violates — learn the pairing, not just the word.

DREAD — risk scoring

Damage · **R**eproducibility · **E**xploitability · **A**ffected users · **D**iscoverability

Don't confuse them: **STRIDE = categorize the threat**; **DREAD = score the risk.** Both appear under Domain 1.3 threat-modeling frameworks (with OCTAVE = asset/risk-based assessment).

Social-engineering influence principles

Authority · Urgency · Scarcity · Reciprocity · Social proof (consensus) · Liking/familiarity · Commitment/consistency

Hook: every pretext pulls one of these levers. When a scenario describes the *trick*, name the lever — and the control is almost always **independent verification** that interrupts the reflex.

Linux privesc checklist (run down it in order)

SUID/SGID · **S**udo rights (`sudo -l`) · **C**ron jobs · **P**ATH hijacking · **C**apabilities (`getcap`) · **K**ernel exploits

Hook: "*Some Sudo Cron Paths Cause Kompromise.*" Windows parallel: unquoted service paths · weak service ACLs · token/impersonation · UAC bypass · kernel.

Testing frameworks (Domain 1.3) — one descriptor each

Framework	What it is
OSSTMM	Methodology manual for security testing
PTES	Penetration Testing Execution Standard (7 phases)
MITRE ATT&CK	Knowledge base of adversary tactics & techniques
OWASP Top 10 / MASVS	Web app risks / Mobile app security verification standard
CREST	Certification & accreditation body for testers
Purdue model	Layered reference model for OT/ICS network segmentation

> **Quick tell:** if the question mentions **OT/ICS layers** → Purdue; **adversary TTPs** → ATT&CK; **mobile** → MASVS.

How to drill this

- **Cover the discriminator, recall it.** For each pair, hide the purple line and try to produce the one-axis difference from memory. That single sentence is what the exam rewards.
- **Turn pairs into two-sided flashcards.** Front: "SSRF vs CSRF?" Back: the discriminator. Same for every pair here.
- **Write the mnemonics by hand once.** Ports and OWASP stick far better after you reproduce them cold on paper twice.
- **Pair with your other three guides:** surface (where), objective map (blueprint), why (mechanism) — and now the pairs/mnemonics that make it all recallable under time pressure.

Authorized use only. These aids support penetration testing within a defined scope and signed rules of engagement. Testing systems you don't own or aren't authorized to assess is illegal.

CompTIA PenTest+ PT0-003 · Domain 4 focus (with high-value cross-domain pairs) · Compare-&-contrast discriminators + mnemonics for cold-recall lists. Companion to the attack-surface, objective-map, and "why" guides. Port/hash lists are common conventions — verify against current references.